

RAPPORT D'AUDIT COMPLET — EDUAI Learning

Date : 2026-07-28

Base : SQLite de test (132 tests passent)

Seed data : seed_test_data.py exécuté (2 écoles, 14 users, 11 contenus)

Branche : phase1-critical

1.1 RBAC — 7 Rôles

UserRole enum

Statut :  Fonctionnel

Preuve : models.py:39-45 — 6 rôles définis

: STUDENT, TEACHER, ADMIN_SCHOOL, SUPER_ADMIN, PEDAGOGICAL_ADMIN, PEDAGOGICAL_LEAD

⚠ Rôle "parent" MANQUANT — Le spec demande 7 rôles. Le rôle parent n'existe nulle part dans le code (pas de UserRole.PARENT, pas de frontend parent, pas de router parent).

Criticité : Majeur (spec non conforme)

Recommandation : Ajouter PARENT = "parent" au UserRole + model ParentChild + endpoints dédiés.

Dépendances RBAC

Statut :  Fonctionnel

Preuve : deps.py — require_admin (super_admin only), require_platform_admin (super_admin + pedagogical_admin), require_school_admin_strict (admin_school + pedagogical_lead), get_current_user (any authenticated)

Endpoints protégés

Statut :  Fonctionnel

Preuve : Tous les routers importent require_admin, require_platform_admin, ou require_school_admin_strict pour les opérations sensibles. Les endpoints publics (login, register, catalog) utilisent get_current_user ou aucun guard.

Endpoints non gardés identifiés :

- GET /api/pathway/niveaux-etude — accessible à tout utilisateur authentifié (pas de restriction rôle)
- GET /api/pathway/matieres — idem
- GET /api/pathway/chapter-pathways — idem
- GET /api/pathway/notions-list — idem

- GET /api/pathway/contenus — idem

Ces endpoints sont en lecture seule et n'exposent pas de données sensibles, mais pourraient être restreints.

Criticité : Mineur

Recommandation :

Ajouter `require_platform_admin` ou `require_school_admin_strict` sur les endpoints CRUD.

1.2 Isolation Multi-Tenant

Event listener SQLAlchemy

Statut :  Fonctionnel

Preuve : `db/session.py` — `_add_tenant_filter` injecté via `Session.do_orm_execute`.

Filtre `school_id == current_tenant_id` sur tous les modèles avec `school_id`.

Tests d'isolation

Statut :  Fonctionnel

Preuve : `test_tenant_filter.py` — 8 tests passent :

- Admin A ne voit que les cours/écoliers de l'école A
- Admin B ne voit que les cours/écoliers de l'école B
- Super_admin voit tout
- Pedagogical_admin voit tout

Contournements du filtre

Statut :  Fonctionnel

Preuve : `db/session.py:38-42` — `current_tenant_id =`

`None` pour `super_admin` et `pedagogical_admin`, supprimant le filtre.

Risque résiduel

Les endpoints RBAC pédagogiques (GET /specialites-pedagogiques) utilisent `current_user.school_id` au lieu du filtre event listener. Un `super_admin` sans `school_id` verrait toutes les spécialités — comportement correct.

Criticité : Aucun problème identifié.

1.3 Wallet à Pockets (Ledger Append-Only)

Système 1 : `WalletTransaction` (nouveau) — APPEND-ONLY CONFIRMÉ

Statut :  Fonctionnel

Preuve : models.py:1533-1558 — Modèle avec commentaire "ONLY INSERT — no UPDATE, no DELETE".

Aucun db.update() ou db.delete() sur WalletTransaction trouvé dans le code.

Preuve : services/wallet.py:122-128 — consume_credits() utilise SELECT FOR UPDATE + INSERT atomique.

Système 2 : User.token_balance / User.dt_balance (legacy) — PROBLÈME CRITIQUE

Statut :  Non fonctionnel (sécurité)

Preuve : admin.py:252-255 — user.token_balance = token_balance (overwrite direct, aucune Transaction créée)

Preuve : admin.py:581-584 — PUT /users/{user_id}/balance (overwrite direct, aucune Transaction)

Preuve : users.py:89-92 — School admin peut overwrite les balances sans audit trail

3 endpoints permettent de modifier les soldes SANS créer d'entrée de ledger. C'est une faille d'auditabilité critique.

Criticité : Bloquant (audit trail incomplet, risque de fraude)

Recommandation : Supprimer les 3 endpoints de overwrite direct. Toute modification de solde doit passer par un système de Transaction.

Deux systèmes parallèles et incohérents

Statut :  Partiel

Preuve : models.py:311-312 (token_balance, dt_balance mutable)
vs models.py:1533 (WalletTransaction append-only)

Le système WalletTransaction n'est utilisé QUE pour les crédits IA (6 features billing). Les achats de packs et de cours utilisent encore User.dt_balance (legacy). Ces deux systèmes ne se communiquent pas.

Criticité : Majeur (complexité technique, risque d'incohérence)

Recommandation : Migration progressive vers le système WalletTransaction pour toutes les transactions.

Ordre de consommation

Statut :  Fonctionnel (nouveau système uniquement)

Preuve : wallet.py:135-139 — Priorité : SUBSCRIPTION → SCHOOL_ALLOCATED → TRIAL → PURCHASED (plus périssable en premier)

1.4 StudyPack — Vérification Dynamique d'Accès

Vérification à chaque requête

Statut :  Fonctionnel

Preuve : services/course_access.py:20-

85 — has_course_access() interroge PackPurchase en DB à chaque appel avec valid_until > now.

Preuve : services/student_tier.py:24-

58 — get_student_tier() interroge PackPurchase en DB à chaque appel.

Preuve : routers/adaptive_pathway.py:960-992 — Vérification pack à chaque accès pathway.

Absence de cache

Statut :  Fonctionnel

Aucun cache Redis ou in-memory sur les résultats d'accès pack. Chaque requête est une interrogation DB fraîche.

Expiration automatique

Statut :  Fonctionnel

Preuve : services/course_access.py:104-146 — APScheduler toutes les heures, met à jour PackPurchase.status = "expired" quand valid_until < now.

1.5 Parcours Pédagogique Adaptatif (10 Règles)

Couche 1 — Arborescence

Statut :  Fonctionnel

Preuve : models.py:1781-1842 — NiveauEtude → Matiere → ChapterPathway → Notion. Tous les modèles existent avec FK correctes.

Couche 2 — ContenuNotion + Publication

Statut :  Fonctionnel

Preuve : test_adaptive_pathway.py::test_standard_seul_brouillon — PASSED (Standard seul → brouillon)

Preuve : test_adaptive_pathway.py::test_standard_plus_avance_publicable — PASSED (Standard + Avancé → publicable, manquants=[REMEDIATION])

Preuve : services/adaptive_pathway.py:56-75 — statut_publication() vérifie Standard + (Remédiation OU Avancé)

Couche 3 — ProfilAssimilationEleve

Statut :  Fonctionnel

Preuve : test_adaptive_pathway.py::test_sans_profil_retombe_default — PASSED (sans profil → fallback matière)

Preuve : test_adaptive_pathway.py::test_reorientation_auto_appliquee — PASSED (scores bas → réorientation auto + notification)

Preuve : services/adaptive_pathway.py:131-198 — niveau_effectif() résout par chapitre avec repli matière

Preuve : services/adaptive_pathway.py:199-262 — evaluer_reorientation() crée profil + notification enseignant

Couche 4 — Packs Commerciaux

Statut :  Fonctionnel

Preuve : models.py:728-809 — StudyPack (4 types : Mono-Matière, À la Carte, Full Level, Sur-Mesure) + PackPurchase

Preuve : services/adaptive_pathway.py:362-412 — acces_effectif() résout dynamiquement, y compris pour Sur-Mesure

Couche 5 — Accès Effectif Dynamique

Statut :  Fonctionnel

Preuve : test_adaptive_pathway.py::test_acces_refleete_nouveau_niveau — PASSED (après réorientation, acces_effectif reflète le nouveau niveau, pas le scope_achat)

Preuve : test_adaptive_pathway.py::test_fallback_vers_standard — PASSED (contenu manquant → fallback Standard)

Tests 7-10 (RBAC Pédagogique)

Statut :  Fonctionnel

Preuve : 4 tests RBAC passent (resp. sciences voit 2 matières, scopes disjoints, contenu EN_ATTENTE invisible, rejet remet A)

Total : 10/10 règles testées et passées.

1.6 RBAC Responsables Pédagogiques par Spécialité

SpecialitePedagogique scopée par école

Statut :  Fonctionnel

Preuve : models.py:1937-1948 — ecole_id FK sur specialites_pedagogiques

Preuve : routers/adaptive_pathway.py:954-976 — GET /specialites-pedagogiques filtre par current_user.school_id

Filtrage espace de travail

Statut :  Fonctionnel

Preuve : services/adaptive_pathway.py:480-512 — contenu_visible() vérifie matière dans spécialité + niveau_etude dans scope

Preuve : test_adaptive_pathway.py::test_8_deux_responsables_scopes_disjoints — PASSED (resp. 7eme ne voit pas contenu Bac)

Validation pédagogique indépendante

Statut :  Fonctionnel

Preuve

: test_adaptive_pathway.py::test_9_contenu_en_attente_non_visible_eleve — PASSED (statut_pedagogique=C + EN_ATTENTE → invisible)

Preuve : services/adaptive_pathway.py:413-418 — visible_eleve() vérifie les deux champs indépendamment

Rejet avec retour en A

Statut :  Fonctionnel

Preuve : test_adaptive_pathway.py::test_10_rejet_remet_statut_a — PASSED (rejet remet A, efface valide_par, stocke commentaire)

1.7 Autres Modules

Objectifs à 5 horizons

Statut :  Fonctionnel

Preuve : test_goal_tracking.py — 15/15 tests passent

Preuve : services/goal_tracking.py:202 — compute_goal_status() recalcul dynamique à chaque appel

Preuve : services/goal_scheduler.py:55 — Scheduler APScheduler cron 00:05 daily

Preuve : services/school_calendar.py:31-44 — Calendrier tunisien 2025-2026 (3 trimestres)

Cycle de vie du cours

Statut :  Fonctionnel

Preuve : services/course_lifecycle.py:11 — Machine à états complète avec 11 transitions valides

Preuve : `